



# Dossier Technique & Commercial

Plateforme SaaS RH / Pointage

|                    |                                                                                      |
|--------------------|--------------------------------------------------------------------------------------|
| Plateforme web     | Concorde Workforce                                                                   |
| Application mobile | Concorde Workly                                                                      |
| Cycle              | Préparation lancement V1                                                             |
| Date               | 17 mai 2026 — Version 2                                                              |
| Backend            | .NET 8 · ASP.NET Core · PostgreSQL 16                                                |
| Frontend           | React 19 · Vite · MUI · TypeScript 5                                                 |
| Mobile             | Expo SDK 54 · React Native 0.81                                                      |
| Infra              | Serveur dédié OVH KS-5-B (France) · Ubuntu Server 24.04 LTS · Docker Compose · nginx |
| IA                 | Qdrant (RAG) · LangChain · multilingual-e5-large                                     |

*Document confidentiel — usage interne & partenaires autorisés*

# Table des matières

---

1. Synthèse exécutive
2. Architecture fonctionnelle
3. Modules existants
4. Workflows
5. Sécurité mobile renforcée (G1 → G6)
6. Sécurité backend & infrastructure
7. APIs et architecture des services
8. Gestion des rôles et permissions
9. Performances et scalabilité
10. Modules livrés et axes d'enrichissement
11. Stratégie SaaS et segmentation des offres
12. Packs tarifaires et fonctionnalités
13. Application mobile Concorde Workly
14. Éléments pour démonstrations commerciales
15. Scénarios opérationnels anticipés
16. Roadmap de développement
17. Plan de durcissement infrastructure de production
18. Services tiers et dépendances
19. Annexes juridiques et conformité
20. Conclusion

# 1. Synthèse exécutive

---

## 1.1 Vision produit

Plateforme SaaS multi-tenant proposant aux PME/ETI une solution intégrée :

- Pointage présentiel et mobile avec géolocalisation
- Gestion RH (employés, contrats, congés, RTT, absences, sanctions)
- Préparation paie (rubriques, états périodiques, exports)
- Coffre-fort numérique pour documents salariés (bulletins, contrats, justificatifs)
- Signature électronique des documents
- Dashboards & reporting analytiques
- Assistant IA contextuel (RAG)

## 1.2 Maturité actuelle

- **Backend** : 64 contrôleurs API, 131 entités EF Core, multi-tenant master/tenant opérationnel, RAG branché, auto-migration de schéma au démarrage, seed automatique du référentiel pays.
- **Web** : ~30 modules métier complets en MUI, i18n FR/EN, animations, dashboard admin/employé/manager différencié.
- **Application mobile** (22 pages) : authentification par empreinte digitale ou reconnaissance faciale, géolocalisation GPS pour le pointage, notifications instantanées, signature électronique manuscrite, coffre-fort de documents personnels, et protection de la confidentialité (blocage des captures d'écran, détection des appareils piratés, etc.).
- **Tarification Early Launch** : Starter 29,50 € · Standard 54 € · Premium 149 € — *offre de lancement réservée aux 10 premières entreprises partenaires*, engagement annuel, 1 mois gratuit sans CB. Facturation forfait + overage Stripe.
- **Plafonds packs (cap dur)** : Starter 30 salariés max, Standard 100, Premium 200 — au-delà, basculement vers offre Enterprise sur devis.
- **Quotas stockage** : 5 Go (Starter) · 20 Go (Standard) · 100 Go (Premium), mesurés via `pg_database_size + uploads/{slug}/`, sweep horaire.
- **Plan gating opérationnel** : restrictions backend ( `RequirePlanFeatureAttribute` ), frontend ( `planAllows` ) et mobile.
- **Anti-fraude au signup** : validation SIRET/BCE/ICE/NINEA contre registres officiels (Sirene, CBE), index unique filtré côté master DB, sélecteur pays FR/BE/MA/SN dynamique (cf. §6.5), filtrage des emails grand public (Gmail/Outlook/Yahoo...) au profit de l'email professionnel.
- **Durcissement authentification** : account logout progressif, vérification HIBP Pwned Passwords, alerte instantanée sur nouvel appareil avec lien sécurisé HMAC de révocation (cf. §3.1 et §6.5).
- **Protections paiement** : idempotence Stripe Checkout, anti-replay des webhooks via `StripeWebhookSeen`, validation server-side du `userCount` au checkout, produit Stripe unique `user_supp` pour les collaborateurs supplémentaires.
- **Politique de résiliation** : remboursement prorata temporis automatique sur les abonnements annuels résiliés en cours de période, via Refund API Stripe (cf. §11.3).
- **Infrastructure** : déployable via `docker compose up`, certificats Let's Encrypt, HSTS + CSP + headers complets, isolation per-tenant des uploads ( `uploads/{slug}/` ).

## 1.3 Cibles V1 (lancement)

| Objectif                    | Détail                  | Statut     |
|-----------------------------|-------------------------|------------|
| Multi-tenant billing Stripe | Base + seat items       | ✓ Fait     |
| Pointage géolocalisé        | Fiable cross-fuseau     | ✓ Fait     |
| Coffre-fort + signature     | Flux complet            | ✓ Fait     |
| Préparation paie            | Exports Excel standards | ✓ Fait     |
| Hardening sécurité          | OWASP top 10 + mobile   | ✓ Fait     |
| Infra production durcie     | Ubuntu 24.04 LTS        | ☐ En cours |

## 2. Architecture fonctionnelle

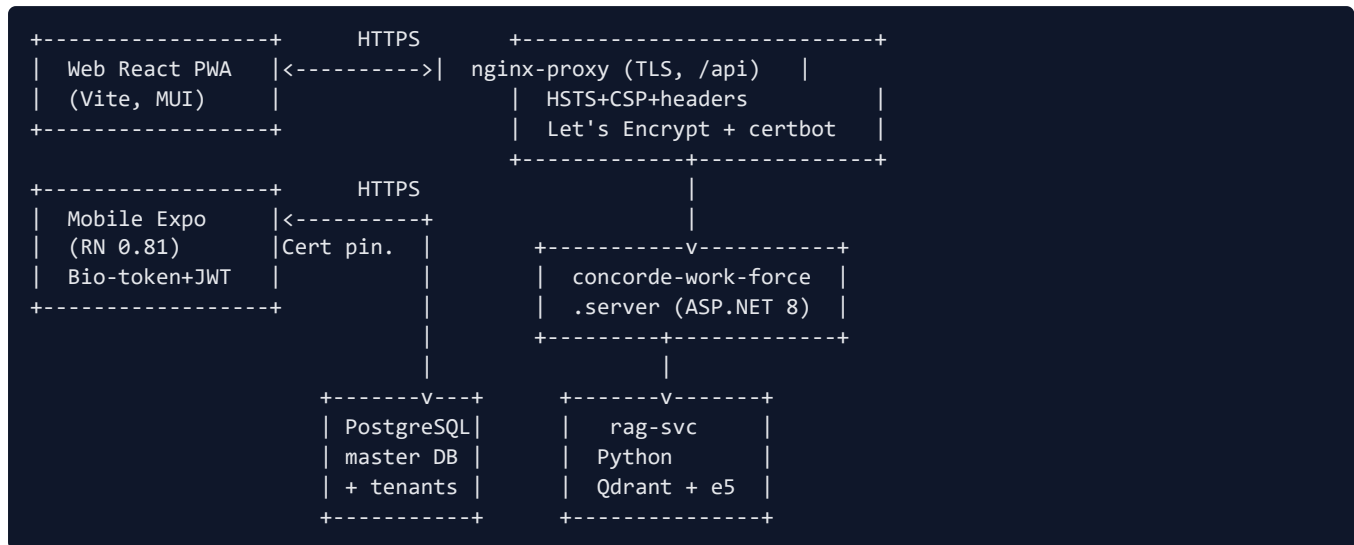
### 2.1 Architecture de marque

La solution se compose de deux produits commercialement distincts mais techniquement intégrés, sous l'ombrelle du groupe **Concorde** (éditeur : concorde-tech.fr) :

|                                                                                     | Marque                    | Périmètre                                                                                                                                                                                                                         |
|-------------------------------------------------------------------------------------|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <b>Concorde Workforce</b> | Plateforme web SaaS d'administration RH et de gestion du temps — destinée aux administrateurs, managers et services paie. Tableau de bord, configuration référentielle, validation des demandes, préparation paie, reporting.     |
|  | <b>Concorde Workly</b>    | Application mobile compagnon (iOS / Android) destinée aux salariés sur le terrain. Pointage géolocalisé, signature électronique, coffre-fort de documents personnels, demandes de congés, consultation du solde et des plannings. |

Les deux produits partagent le même backend (API REST), la même base de données multi-tenant et le même socle d'authentification — la séparation est exclusivement éditoriale et UX.

## 2.2 Vue d'ensemble technique



## 2.3 Stack technologique

| Couche         | Technologies principales                                                                                                                                                                                                          |
|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Backend API    | .NET 8 · ASP.NET Core · EF Core 8 · Dapper 2.1 · AutoMapper 14 · MailKit · BCrypt · Otp.NET (TOTP) · QRCode · Stripe.NET 47 · DinkToPdf · FastReport.OpenSource · DocumentFormat.OpenXml · PdfPig · Microsoft.SemanticKernel 1.30 |
| Web            | React 19 · Vite · TypeScript 5 · MUI 5 + x-charts + x-data-grid + x-date-pickers · React Query 5 · React Router · FullCalendar · jsPDF + autotable · ExcelJS · i18next FR/EN · dayjs · Recharts · axios                           |
| Mobile         | Expo SDK 54 · React Native 0.81 · React Navigation 7 · expo-location · expo-camera · expo-document-picker · expo-secure-store · expo-notifications · expo-local-authentication · expo-screen-capture · React Native Paper         |
| Infrastructure | Docker Compose · nginx (proxy + TLS) · PostgreSQL 16 · Qdrant 1.12 · Python sidecar RAG (LangChain + multilingual-e5-large) · certbot                                                                                             |
| CI/CD          | GitHub Actions — pipelines automatisés (build multi-stage, tests, publication images Docker, déploiement) déclenchés à chaque push sur la branche principale                                                                      |

## 2.4 Topologie Docker Compose

| Service                      | Image                             | Réseau                | Volumes                   |
|------------------------------|-----------------------------------|-----------------------|---------------------------|
| nginx-proxy                  | nginx:alpine                      | app-network 80/443    | nginx.conf:ro, uploads RO |
| concorde-work-force.server   | concorde-work-force-server:local  | app-network 8080      | uploads_data RW           |
| concorde-work-force.client   | concorde-work-force-client:latest | app-network 80        | —                         |
| concorde-work-force.database | postgres:16-alpine                | app-network           | postgres-data, pg-backup  |
| qdrant                       | qdrant:1.12.0                     | app-network 6333/6334 | qdrant_data               |

| Service | Image                             | Réseau           | Volumes          |
|---------|-----------------------------------|------------------|------------------|
| rag-svc | concorde-work-force-rag-svc:local | app-network 8080 | —                |
| certbot | certbot/certbot                   | —                | letsencrypt_data |

## 2.5 Multi-tenant SaaS

**Modèle** : *Database-per-tenant + master DB.*

```

Master DB (ABRPOINT_master)      Tenant DBs (ABRPOINT_<slug>)
+-----+                        +-----+
| Tenants (slug, host) |      | Sites, Employes, |
| TenantEmailIndex    |      | Presences, Vault, etc. |
| Plans, Subscriptions |      | (schema migre a chaud) |
+-----+                        +-----+

```

- **Résolution tenant** : `TenantResolverMiddleware` lit le header `X-Tenant-Slug` ou le sous-domaine.
- **DbContext factory dynamique** : connection string générée via `TenantTemplate` si tenant résolu.
- **Auto-migration** : `BaseDataSchemaMigrator` applique les ALTER TABLE/CREATE INDEX idempotents. Un simple `docker compose up -d` propage les évolutions de schéma.

## 2.6 Modèle de données (haute densité)

131 entités organisées par familles :

| Famille         | Entités principales                                                                        |
|-----------------|--------------------------------------------------------------------------------------------|
| RH socle        | Employe, Empuser, Direction, Fonction, Service, Section, Qualif, Site, Societe, Ville      |
| Pointage        | Presence, Pointeuse, Dmpresence                                                            |
| Horaires        | Poste, Lposte, Calendsoc, Lcalendsoc, Ferier                                               |
| Congés/absences | Conge, Demconge, Absence, Sanction, DemandeAutorisation, Autoriser, Allaitement, Compenser |
| Paie            | Rubrique, NoteDeFrais, Mission                                                             |
| Gestion droits  | Roles, RolePermission, RolePointdroit, Module, Modusers                                    |
| Contrats/docs   | Contrat, DocumentVault, LetterTemplate                                                     |
| Tenancy         | Tenant, TenantEmailIndex (master DB)                                                       |
| Audit/sécu      | AuditLog, RefreshToken                                                                     |
| Notifications   | PushToken, Notification, NotificationCategoryCatalog                                       |
| RAG/IA          | RagDocument, RagLetterTemplate, RagChatLog, index Qdrant                                   |

## 3. Modules existants

### 3.1 Authentification & sécurité

- **Login web/mobile** : email + mot de passe BCrypt, JWT 8.0
- **2FA TOTP** : QR code via QRCodeur lors de l'enrôlement, validation à chaque login
- **Tokens** : access token courte durée + RefreshToken long terme chiffré AES
- **Mobile biométrie sans password** (G2) : bio-token dédié (purpose=Biometric, expiry 90j, rotation à chaque usage). Aucun mot de passe stocké sur l'appareil.
- **Quota refresh tokens par utilisateur** (G6) : 5 derniers tokens actifs maximum, les plus anciens révoqués automatiquement.
- **Account lockout progressif** ([UtilisateursController.cs]) : compteur d'échecs `uti_failed_logins` + `uti_locked_until`. Paliers OWASP : 3 échecs → 30 s, 5 → 5 min, 10 → 1 h, 20+ → 24 h. Réinitialisé à chaque login réussi. Combiné au rate-limit IP `auth-login`, bloque le brute-force credential-stuffing.
- **Vérification HIBP Pwned Passwords** ([PasswordBreachCheckService.cs]) : au signup, changement et reset de mot de passe, k-anonymity SHA-1 (5 premiers hex envoyés seulement), header `Add-Padding: true` (anti corrélation taille de réponse). Mode *fail-open* si l'API HIBP est indisponible — la disponibilité du service n'est pas dépendante d'un tiers.
- **Alerte connexion depuis un nouvel appareil** ([KnownDeviceService.cs]) : table `known_devices(uticod, ua_hash, ip_prefix)`. SHA-256 UA tronqué (16 hex) + préfixe IP (/16 IPv4, /48 IPv6). Si combinaison inconnue ET pas la toute première connexion de l'utilisateur, e-mail instantané « Connexion depuis un nouvel appareil détectée » avec lien sécurisé « *Ce n'était pas moi* » signé HMAC-SHA256, TTL 7 j, usage unique via `IMemoryCache`. Le clic révoque tous les refresh tokens, réinitialise le lockout, génère un code de reset 6 chiffres et envoie un e-mail de récupération ([AuthLookupController.RevokeSuspiciousLogin], [SuspiciousLoginTokenService.cs] — `CryptographicOperations.FixedTimeEquals` pour comparaison anti-timing).
- **Anti-énumération** : tous les contrôleurs `[Authorize]` + `[ValidateSoccod]`, refresh token rotatif.

### 3.2 Gestion RH

- CRUD complet employé + fiche enrichie (état civil, banque, compétences, sites)
- Hiérarchie : Direction > Service > Section
- Import Excel (rubriques, employés via `BulkImportController`)

### 3.3 Pointage & présences

- Pointage manuel (web admin) via état périodique
- Pointage employé (mobile) avec capture GPS, accuracy, horodatage local
- Calculs dédiés : `HeureSuppService`, `HeuresAbsencesService`, `CalcTotHeuresService`, `PointageMoisService`, `PointageOptimizer`
- États : périodique, journalier, retards, assiduité, global

### 3.4 Pointage géolocalisé

- Colonnes `sitlat`, `sitlon`, `sitrad` (rayon m) créées automatiquement par `BaseDataSchemaMigrator`
- Validation Haversine (`GeoZoneValidator.cs`) — source DB prioritaire + fallback config
- Contrôle au pointage : refus 422 `gps_required` / `outside_geofence` si hors rayon



- Tolérance horloge : skew client / serveur tolérant (jusqu'à 90 min) — couverture Maroc / Europe DST sans rejet de pointage

### 3.5 Congés & autorisations

- Workflow : soumission → manager/admin approve/refuse → titre de congé émis
- RTT : crédit, consommation, solde annuel par employé
- CET (compte épargne temps) : conversion congés non pris
- Demandes d'autorisation de sortie + Autorisations approuvées

### 3.6 Préparation paie

- Rubriques : CRUD, Excel import, formules
- Pointage du mois : agrégation présences par employé, thread-safe (DbContext scoped)
- Export paie : DocumentFormat.OpenXml (Excel) et PDF
- Bulletins via `LetterTemplates` (templates HTML/Razor-like personnalisables)

### 3.7 Coffre-fort numérique

- Upload via FormData multipart (mobile + web)
- Whitelist extensions : pdf, doc/docx, xls/xlsx, csv, png/jpg — bloque exécutables et SVG/HTML scriptables
- Plafond 10 Mo par fichier (override via env `Uploads__MaxSizeMb`)
- Path traversal : noms régénérés en GUID, jamais du nom client
- Audit orphelins : endpoint admin réconciliant DB ↔ filesystem
- Téléchargement direct via nginx (volume `uploads_data` RO) — sans hop backend

### 3.8 Signature électronique

- Web : SignaturePad + base64 → backend via `SaveBase64Image`, fichier `sig_*.png`
- Mobile : capture tactile, upload, statut signé verrouille la suppression. Les captures d'écran sont automatiquement bloquées pendant la session de signature pour préserver la confidentialité du document signé.
- Métadonnées : signataire, date, IP — visibles dans l'audit log

### 3.9 Notifications & reporting

- Push mobile via Expo Push API, tokens stockés en `PushToken`
- Email : MailKit + SMTP, templates HTML
- In-app : centre de notifications web + mobile, badge unread
- Quiet hours : blocage des notifications hors plage horaire configurée
- Rappels ponctualité : service hébergé balayant périodiquement
- PDF : DinkToPdf (HTML→PDF), FastReport pour états réguliers
- Excel : DocumentFormat.OpenXml (backend) + ExcelJS (web)

### 3.10 Inscription, abonnement & cycle de vie tenant

Module ajouté au cours du sprint mai 2026, alignant l'expérience d'achat sur les standards SaaS (Odoo, HubSpot) et la conformité légale française.

- **Inscription publique anti-bot** : page `/signup` protégée par *captcha mathématique* côté serveur (challenge arithmétique généré, validation à usage unique via `IMemoryCache` avec TTL 5 min) — pas de dépendance externe Google reCAPTCHA, RGPD-friendly
- **Sélecteur pays (FR / BE / MA / SN)** : drapeaux servis par l'API publique `restcountries.com` (même source que la fiche collaborateur, pour cohérence) ; le champ d'identifiant entreprise change dynamiquement selon le pays choisi — SIRET 14 chiffres FR, BCE 10 chiffres BE, ICE 15 chiffres MA, NINEA 9 caractères SN — avec validation backend dédiée par pays (cf. §6.5)
- **Anti-fraude par identifiant entreprise** ([`SiretValidationService.cs`]) : appels API officiels — `api-recherche-entreprises.fr` (Sirene FR) et `cbeapi.be` (Bearer-auth BE), validation algorithmique *mod 97* BE en file, format-only MA/SN (pas d'API publique stable). **Index unique filtré** côté master DB `UX_Tenants_Siret_Active WHERE Siret IS NOT NULL AND Status NOT IN ('Failed', 'Cancelled')` — un même établissement ne peut pas obtenir plusieurs essais gratuits en parallèle
- **Vérification HIBP du mot de passe au signup** (cf. §3.1) : si le mot de passe figure dans les fuites publiques ( `pwnedpasswords.com` ), le signup retourne 400 `password_breached` avant la création du tenant
- **Sélection de plan amont** : Starter / Standard / Premium choisis avant création du tenant ; le plan détermine immédiatement les modules visibles (cf. §8 gating)
- **Essai gratuit 30 jours** sur tous les plans (sans CB requise) — politique unifiée mai 2026, anciennement réservée à Standard. Le tenant en essai accède aux modules de *son plan sélectionné* (pas Premium-pour-tous) pour cohérence avec la promesse commerciale et éviter l'effet falaise au paiement
- **Paiement Stripe Checkout** : abonnement récurrent (mensuel ou annuel, configurable par tenant), prix forfaitaire + overage par salarié au-delà du seuil inclus ; webhook signé `customer.subscription`. `{created|updated|deleted}` synchronise l'état tenant ; **idempotence native** : clé `Idempotency-Key` SHA-256 (tenant + plan + cycle + qty + bucket 1 min) sur la création de session Checkout pour bloquer les doublons issus de double-clic ; **anti-replay webhook** : table `StripeWebhookSeen` (event\_id en PK) garantit qu'un même event n'est traité qu'une seule fois côté serveur ; **validation server-side du userCount** : la quantité facturée est plafonnée par le nombre d'employés actifs réellement comptés en base tenant pour empêcher la sous-déclaration frauduleuse
- **Résiliation libre** ([`BillingController.cs`]) : deux modes — *immédiate* (Stripe `CancelAsync`, accès coupé) ou *fin de période* ( `cancel_at_period_end`, l'utilisateur conserve l'accès jusqu'à la date payée). Réservée Admin/Manager via vérification base de données du rôle ( `Utiadm` / `Utirole` )
- **Prorata de remboursement (abonnements annuels uniquement)** : à la résiliation immédiate d'un abonnement annuel, le montant non consommé est remboursé sur la carte de paiement d'origine via la *Refund API* Stripe ; détection par lecture de `Price.Recurring.Interval == "year"` sur les items de subscription, calcul `montantRemboursé = AmountPaid × (secondes restantes / durée totale période)`, idempotence et fail-soft (la résiliation reste effective même en cas d'échec du remboursement, repris manuellement par le support). **Le mensuel reste sans remboursement** (cf. §11.3)
- **Réactivation post-résiliation** conforme au droit français du contrat : tenant en statut `Cancelled` conservé **90 jours en rétention** ; pendant cette fenêtre, l'utilisateur peut se ré-inscrire avec la *même adresse e-mail* et récupérer ses données (l'API `/signup` renvoie le code `cancelled_account_reactivatable` et redirige vers `/login`, l'endpoint `/billing/resume-checkout` accepte les `Cancelled`). Au-delà de 90 jours : suppression effective (RGPD *droit à l'effacement*)
- **Reprise d'abonnement** : avant la date de coupure, l'admin peut annuler la résiliation en un clic (Stripe `cancel_at_period_end = false`)
- **Multi-tenant strict** : `TenantResolverMiddleware` bypass explicitement `/api/billing/*` pour les tenants `Suspended/Cancelled/Failed` afin de permettre le flux de réactivation sans contourner les autres protections

### 3.11 Catalogue de plans & gating commercial (PlanCatalog)

Source de vérité unique [PlanCatalog.cs] côté serveur, exposée au frontend via `/api/Utilisateurs/me` (clé `planFeatures`) et au mobile via `/MobileAuth/me`.

- **19 drapeaux fonctionnels** par plan (booléens) : application mobile, géolocalisation, coffre-fort numérique, signature électronique, multi-site, multi-société, tableaux de bord avancés, IA RAG, audit logs avancés, branding personnalisé, device trust, anti-screenshot, certificate pinning, missions, jours de compensation, congé général, autorisation générale, gestion congés, gestion autorisations
- **Limites quantitatives** : effectifs inclus, tarif overage par employé, nombre max de sociétés/sites — calculées via `PlanCatalog.GetLimits`
- **Plan Starter (29,50 €/mois, 10 salariés inclus, cap pack 30)** : positionnement « pointage simple, sans workflow RH » — exclut explicitement le coffre-fort, la signature électronique, les missions, les jours de compensation, le congé général, l'autorisation générale, la gestion des congés (demande + titre), la gestion des autorisations (saisie + demande), l'assistant IA. **Conserve** l'état périodique du pointage. Stockage 5 Go inclus.
- **Plan Standard (54 €/mois, 15 salariés inclus, cap pack 100)** : ajoute mobile, géolocalisation, coffre-fort, signature, multi-site, dashboards avancés, missions, jours de compensation, congé/sortie générale, workflow congé/autorisation complet — exclut IA RAG, audit logs avancés, branding, sécurité durcie. Stockage 20 Go inclus.
- **Plan Premium (149 €/mois, 30 salariés inclus, cap pack 200, illimité sociétés/sites)** : tout activé, incluant l'IA et le durcissement de sécurité mobile. Stockage 100 Go inclus.
- **Application backend** : attribut `[RequirePlanFeature(nameof(PlanFeatures.X))]` sur les contrôleurs/actions → retourne HTTP 402 avec code stable `plan_feature_locked` que le front transforme en pop-up « Upgradez votre plan »
- **Application frontend** : hook `useAuth().planAllows(feature)` filtre la navigation latérale → les modules verrouillés disparaissent du menu (pas seulement grisés)

## 4. Workflows

### 4.1 Workflow employé (mobile — golden path)

```

Login email/pwd --> (2FA TOTP si active) --> JWT + refresh
|
v (option : enrolement biometrique -> bio-token serveur)
HomeScreen --> [Bouton POINTER]
|               | capture GPS (expo-location, 5s timeout)
|               | POST /Presences/mark-presence/{soc}/{emp}
|               v
|               Backend valide :
|               +- caller owns/manages employee OK
|               +- skew clock <= 90 min OK
|               +- si geofence : GPS requis + dans rayon OK
|               +- dans periode d'emploi OK
|               v
|               INSERT/UPDATE presence + log GPS
|
+---> Vault : upload doc / consulter / signer
+---> Demandes conge / autorisation
+---> Auto-lock apres 10 min inactivite
+---> Notifications push (Expo)

```

## 4.2 Workflow administrateur (web)

Le workflow admin couvre : Données de Base (Filiales, Sites, Villes), Gestion Employés (création, contrats, sanctions), Pointage (état périodique, optimiseur, imports CSV), Congés (workflow approbation), Préparation Paie (rubriques, pointage mois, états PDF), Vault (upload bulk + audit orphelins), et Paramètres (rôles & permissions, plan/billing Stripe, notifications opt-in).

## 4.3 Workflow manager

Sous-ensemble de l'admin scopé à son service/section : approbation congés/autorisations de son équipe, vue dashboard via `ManagerDashboardController`.

## 4.4 Workflow signup tenant (onboarding technique)

```
Landing /signup --> [SignupController] (rate-limited 3/h/IP)
|
v
1. Validation email unicite (master DB -> TenantEmailIndex)
2. Creation Tenant (slug = sous-domaine, host)
3. Creation tenant DB (BaseDataSchemaMigrator clone schema)
4. Provisioning admin initial
5. Stripe customer si plan payant ; trial period sinon
6. Email welcome + login -> tenant scope actif
```

## 5. Sécurité mobile renforcée (G1 → G6)

Six durcissements appliqués en plus du socle JWT/HTTPS :

| ID | Risque                               | Mitigation                                                                                                           | Plan              |
|----|--------------------------------------|----------------------------------------------------------------------------------------------------------------------|-------------------|
| G1 | MITM via CA compromise               | Certificate Pinning (Android <code>network_security_config.xml</code> + iOS <code>NSPinnedDomains</code> )           | Tous (build-time) |
| G2 | Vol credentials sur device           | Bio-token sans password — endpoints <code>/MobileAuth/biometric-*</code>                                             | Standard+         |
| G3 | Reverse-engineering émulateur / root | Device trust assessment ( <code>deviceSecurity.ts</code> ),<br>détection Genymotion / BlueStacks / Nox, OS obsolètes | Premium           |
| G4 | Exfiltration via screenshot          | <code>expo-screen-capture</code> + hook <code>useSecureScreen</code> sur<br>Vault, Signature, Profile                | Premium           |
| G5 | Session orpheline device perdu       | Auto-lock 10 min foreground / 5 min arrière-plan,<br>overlay LockScreen + Face ID                                    | Standard+         |
| G6 | Sessions persistantes infinies       | Quota 5 RT actifs / user, révocation automatique des<br>plus anciens                                                 | Tous              |

**Note sur G1 (cert pinning) :** la configuration est native au binaire mobile et n'est pas désactivable au runtime. Un client Standard bénéficie *de facto* du cert pinning. La valeur différenciante Premium reste G3/G4 (device trust + anti-screenshot).

## 6. Sécurité backend & infrastructure

### 6.1 Surface protégée (OWASP Top 10)

| Vecteur                              | Mitigation                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A01 — Broken Access Control          | [Authorize] + [ValidateSoccod] + permissions par module + caller-owns checks                                                                                                                                                                                                                                                                                                |
| A02 — Cryptographic Failures         | BCrypt (passwords), refresh tokens chiffrés AES, TLS 1.2/1.3 only, HSTS preload 1 an + includeSubDomains                                                                                                                                                                                                                                                                    |
| A03 — Injection                      | EF Core paramétré ; pas de SQL concaténé utilisateur                                                                                                                                                                                                                                                                                                                        |
| A04 — Insecure Design                | Garde-fous métier explicites (skew clock, hire/termination dates, GPS requis si geofence)                                                                                                                                                                                                                                                                                   |
| A05 — Security Misconfig             | Header serveur masqué ( AddServerHeader = false ), server_tokens off côté nginx, erreurs masquées en prod                                                                                                                                                                                                                                                                   |
| A07 — Identification & Auth Failures | 2FA TOTP, refresh rotatif + quota 5/user (G6), rate-limit clock-in (6/min/IP), auth-signup (3/h/IP), auth-login , <b>account lockout progressif par compte</b> (3→30 s, 5→5 min, 10→1 h, 20+→24 h), <b>vérification HIBP Pwned Passwords k-anonymity</b> au signup/change/reset, <b>alerte connexion depuis un nouvel appareil</b> + lien sécurisé de révocation (cf. §6.5) |
| A08 — Software & Data Integrity      | Whitelist d'extensions uploads (anti-RCE), nginx deny sur .php/.exe/.sh dans /api/uploads/                                                                                                                                                                                                                                                                                  |
| A09 — Logging & Monitoring           | Logging structuré ( ILogger<> ), table AuditLog pour actions critiques                                                                                                                                                                                                                                                                                                      |
| A10 — SSRF                           | Sidecar RAG isolé sur réseau interne uniquement                                                                                                                                                                                                                                                                                                                             |
| Path traversal                       | Nommage UUID, répertoire parent constant                                                                                                                                                                                                                                                                                                                                    |
| Mass assignment                      | DTOs explicites, récupération entité serveur avant patch                                                                                                                                                                                                                                                                                                                    |
| CSRF                                 | Stateless JWT (Bearer header) → non applicable                                                                                                                                                                                                                                                                                                                              |

### 6.2 Headers HTTP (nginx-proxy)

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self), camera=(self), microphone=()
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Content-Security-Policy: default-src 'self'; img-src 'self' data: https;;
  style-src 'self' 'unsafe-inline'; script-src 'self' 'unsafe-inline';
  font-src 'self' data:; frame-src 'self' blob:; frame-ancestors 'self';
  base-uri 'self'; form-action 'self';
```

### 6.3 Healthchecks

- GET /healthz → liveness (le process répond)

- `GET /readyz` → readiness (DB ping `SELECT 1`) — utilisable par orchestrateur ou monitoring externe

## 6.4 Auto-migration de schéma

[BaseDataSchemaMigrator.cs] applique au démarrage, par tenant et de façon idempotente, toutes les évolutions de schéma. La **version 3 ajoute** :

- Colonnes `uti_failed_logins`, `uti_locked_until`, `uti_last_failed_login_at` sur la table `Utilisateurs` (lockout progressif)
- Table `known_devices(uticod, ua_hash, ip_prefix, first_seen_at, last_seen_at)` avec index composite (alerte nouvel appareil)
- Colonnes `Tenant.Siret` (NVARCHAR 20) et `Tenant.CountryCode` (NVARCHAR 2) sur la master DB
- Index unique filtré `UX_Tenants_Siret_Active WHERE Siret IS NOT NULL AND Status NOT IN ('Failed', 'Cancelled')` (anti-fraude)
- Table master `StripeWebhookSeen(event_id PK, event_type, processed_at)` (anti-replay webhooks)

Toutes ces migrations sont *idempotentes* — un redéploiement (`docker compose up -d`) propage automatiquement le schéma sur tous les tenants existants sans intervention DBA.

## 6.5 Anti-fraude au signup et durcissement de l'authentification

Couche dédiée empilée sur le socle JWT/2FA. Sa logique : empêcher (i) la fraude par multi-inscription gratuite d'un même établissement, (ii) le brute-force / credential-stuffing, et (iii) la prise de contrôle silencieuse d'un compte légitime.

| Mécanisme                                  | Cible                                              | Implémentation                                                                                                                                                                                                                             | Effet                                                                                                 |
|--------------------------------------------|----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| <b>Validation d'identifiant entreprise</b> | Multi-inscription gratuite par changement d'e-mail | [SiretValidationService.cs] — appel <code>api-recherche-entreprises.fr</code> (FR), <code>cbeapi.be</code> Bearer (BE), mod 97 BE en filet, format-only MA/SN. <code>IHttpClientFactory</code> avec clients nommés, timeout 5 s, fail-open | Entreprise inexistante / format invalide rejetée au signup                                            |
| <b>Index unique filtré sur SIRET</b>       | Doublon d'établissement actif                      | <code>WHERE Siret IS NOT NULL AND Status NOT IN ('Failed', 'Cancelled')</code> sur master DB                                                                                                                                               | Une seconde tentative avec même identifiant et statut actif/trial → <code>siret_already_active</code> |
| <b>HIBP Pwned Passwords</b>                | Compte avec mot de passe déjà compromis            | [PasswordBreachCheckService.cs] — k-anonymity SHA-1 (5 premiers hex), header <code>Add-Padding: true</code> , appliqué au signup + change + reset. Fail-open                                                                               | Mot de passe dans les fuites publiques → 400 <code>password_breached</code>                           |

| Mécanisme                                               | Cible                                    | Implémentation                                                                                                                                                                                                                    | Effet                                                                                            |
|---------------------------------------------------------|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| <b>Account lockout progressif</b>                       | Brute-force / credential-stuffing        | Colonnes <code>uti_failed_logins</code> , <code>uti_locked_until</code> . Paliers OWASP : 3 → 30 s, 5 → 5 min, 10 → 1 h, 20+ → 24 h. Combiné au <code>rate-limit IP auth-login</code>                                             | Un attaquant ne peut pas tester plus de quelques mots de passe / heure sur un compte donné       |
| <b>Captcha mathématique</b>                             | Bots de signup en masse                  | Challenge arithmétique côté serveur, <code>IMemoryCache</code> TTL 5 min, usage unique. <i>Pas de Google reCAPTCHA</i> (RGPD)                                                                                                     | Bloque l'automatisation naïve, sans tracker tiers                                                |
| <b>Alerte nouvel appareil</b>                           | Prise de contrôle silencieuse            | Table <code>known_devices</code> . SHA-256 UA tronqué 16 hex + IP /16 (IPv4) ou /48 (IPv6). Pas d'alerte au tout premier login                                                                                                    | L'utilisateur légitime reçoit l'alerte en temps réel                                             |
| <b>Token « Was that me? » HMAC</b>                      | Action sécurisée depuis un e-mail        | [ <code>SuspiciousLoginTokenService.cs</code> ] — payload <code>{slug} {uticod} {issuedAtUnix}</code> signé HMAC-SHA256, TTL 7 j, usage unique <code>IMemoryCache</code> , comparaison <code>FixedTimeEquals</code> (anti-timing) | Le clic révoque tous les refresh tokens, reset lockout, génère code de reset 6 chiffres + e-mail |
| <b>Idempotence Stripe Checkout</b>                      | Doublon par double-clic / retry          | Clé <code>Idempotency-Key</code> SHA-256(tenant + plan + cycle + qty + bucket 1 min)                                                                                                                                              | Double-clic = 1 seule session Stripe                                                             |
| <b>Anti-replay webhooks Stripe</b>                      | Rejeu malveillant ou doublon réseau      | Table master <code>StripeWebhookSeen</code> (PK = <code>event_id</code> ). INSERT en début de pipeline → violation PK = event déjà traité, retour <code>200 OK</code> sans rejouer                                                | Un même event ne déclenche jamais deux fois la mutation <code>Tenant.Status</code>               |
| <b>Validation server-side du <code>userCount</code></b> | Sous-déclaration frauduleuse au checkout | <code>billedQty = Math.Max(requestedQty, COUNT(Empactif='A'))</code> plafonné à 10 000, log warning si correction                                                                                                                 | Un attaquant ne peut pas payer le forfait minimum pour 500 employés                              |

**Conformité RGPD** : aucun de ces mécanismes n'envoie de PII hors UE. HIBP reçoit uniquement les 5 premiers hex SHA-1 (k-anonymity, aucun hash complet ne sort). Sirene et CBE reçoivent uniquement un

identifiant légal d'entreprise public. L'IP est tronquée avant stockage (/16 IPv4, /48 IPv6) — empreinte au sens RGPD non identifiante directe, finalité documentée (détection de prise de contrôle).

## 7. APIs et architecture des services

### 7.1 Conventions REST

- Préfixe `/api`
- Routes : `/api/<Resource>` + `/soccod/...` quand soccod fait partie du chemin
- **Statuts métier custom** : `402` (quota plan dépassé), `422` (règle métier violée), `403` (permission refusée)
- **Headers requis** : `Authorization: Bearer <jwt>`, `X-Tenant-Slug`

### 7.2 Services horizontaux

| Service                                       | Rôle                                                                          |
|-----------------------------------------------|-------------------------------------------------------------------------------|
| <code>EncryptionService</code>                | Chiffrement symétrique des refresh tokens et données sensibles                |
| <code>EmailService</code>                     | Envoi MailKit avec templates HTML                                             |
| <code>ExpoPushService</code>                  | Push mobile via Expo Push API (batchs, retries, nettoyage des tokens expirés) |
| <code>GeoZoneValidator</code>                 | Validation Haversine geofence (DB + configuration)                            |
| <code>PunctualityReminderHostedService</code> | Background service de rappels de ponctualité                                  |
| <code>QuietHoursResolver</code>               | Filtre des notifications hors plage horaire                                   |
| <code>AiService</code> + <code>Rag/</code>    | Indexation, recherche sémantique et génération IA                             |
| <code>BaseDataSchemaMigrator</code>           | Provisionnement du schéma tenant à la volée                                   |

## 8. Gestion des rôles et permissions

### 8.1 Modèle

- **Role** : `Administrator`, `Manager`, `ResponsableRH`, `Employe`, `Comptable`
- **RolePermission** : matrice rôle × module avec drapeaux `RpConsult`, `RpAdd`, `RpModify`, `RpDelete`
- **Modules** : ~30 modules métier
- `Utiadm = '1'` : super-admin tenant, bypass total

### 8.2 Plan gating (verrouillage par pack commercial)

| Couche  | Mécanisme                                                                                                                   | Comportement en cas de refus                                                                                   |
|---------|-----------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| Backend | Attribut <code>[RequirePlanFeature(...)]</code> sur contrôleur / action, résolu par réflexion sur <code>PlanFeatures</code> | HTTP <code>402</code> avec payload <code>{ code: "plan_feature_locked", feature, currentPlan, message }</code> |



| Couche       | Mécanisme                                                                                   | Comportement en cas de refus                                                                    |
|--------------|---------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Frontend web | Hook <code>useAuth().planAllows('featureKey')</code> alimenté par <code>/me</code>          | Éléments de navigation masqués ; intercepteur axios redirige les 402 vers <code>/upgrade</code> |
| Mobile       | <code>AuthContext.user.planFeatures</code> rempli au login et à <code>/MobileAuth/me</code> | Hooks <code>useDeviceTrust</code> / <code>useSecureScreen</code> désactivés hors Premium        |

### Endpoints gâtés :

| Endpoint                                                  | Feature requise     | Effet pour Starter        |
|-----------------------------------------------------------|---------------------|---------------------------|
| POST <code>/api/MobileAuth/login</code>                   | MobileApp           | App mobile inaccessible   |
| POST <code>/api/Presences/mark-presence</code> (avec GPS) | Geolocation         | Refus 402                 |
| Toutes routes <code>/api/Vault/*</code>                   | DigitalVault        | Coffre masqué             |
| POST <code>/api/Vault/sign/{id}</code>                    | ElectronicSignature | Refus 402                 |
| Toutes routes <code>/api/Rag/*</code>                     | RagAi               | Assistant IA inaccessible |

**Pendant l'essai gratuit** (statut `Trialing`), `RequirePlanFeatureAttribute` accorde toutes les features pour permettre l'évaluation complète. La facturation démarre à la conversion.

## 9. Performances et scalabilité

### 9.1 Techniques en place

- EF Core : `AsNoTracking()` sur tous les reads, queries projetées, pas de N+1 connus
- Pagination systématique
- Cache permissions ( `IMemoryCache` ttl ~1 minute)
- Uploads statiques servis directement par nginx — bypass backend, CDN-friendly

### 9.2 Roadmap d'optimisation technique

Plan d'évolution continue pour anticiper la montée en charge et accompagner la croissance commerciale au-delà du périmètre actuel.

| # | Axe d'évolution                                                             | Bénéfice attendu                                                              |
|---|-----------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| 1 | Mise en pool des connexions base ( <code>IDbContextFactory&lt;&gt;</code> ) | Optimisation de la latence pour les déploiements à fort volume (>200 tenants) |
| 2 | Génération PDF asynchrone (queue Hangfire)                                  | Meilleure réactivité sur les exports massifs (paie, rapports annuels)         |
| 3 | Cache distribué Redis ( <code>IDistributedCache</code> )                    | Préparation au déploiement multi-instance pour la haute disponibilité         |

| # | Axe d'évolution                                   | Bénéfice attendu                                                          |
|---|---------------------------------------------------|---------------------------------------------------------------------------|
| 4 | Tests end-to-end automatisés (Playwright / Detox) | Renforcement de la couverture qualité au-delà des tests unitaires actuels |
| 5 | Indexation RAG temps réel sur dépôt de document   | Disponibilité immédiate des nouveaux documents dans l'assistant IA        |
| 6 | Read replicas régionales PostgreSQL               | Réduction de la latence pour les tenants hors Europe                      |
| 7 | Observabilité APM (OpenTelemetry + Grafana)       | Diagnostic proactif et tableaux de bord d'exploitation enrichis           |

## 10. Modules livrés et axes d'enrichissement

### 10.1 Modules finalisés

| Module                                       | Statut                         |
|----------------------------------------------|--------------------------------|
| Auth login + 2FA                             | ✓ Complet                      |
| Bio-token mobile (sans password)             | ✓ Backend + mobile             |
| Multi-tenant master/tenant + auto-migration  | ✓ Complet                      |
| Pointage manuel + mobile                     | ✓ Complet                      |
| Géolocalisation pointage                     | ✓ Schéma + service + UI        |
| Calculs présence / retard / heures sup.      | ✓ Tests unitaires              |
| Congés (demandes, titres, RTT, CET)          | ✓ Workflow complet             |
| Autorisations de sortie                      | ✓ Complet                      |
| Coffre-fort (web + mobile)                   | ✓ Audit orphelins admin        |
| Signature électronique                       | ✓ Web + mobile                 |
| Notifications push + email + in-app          | ✓ Quiet hours + catalogue      |
| Dashboard admin / manager / employé          | ✓ Animations count-up          |
| Reporting PDF / Excel                        | ✓ Suite complète               |
| Préparation paie (rubriques + pointage mois) | ✓ Exports complets             |
| Stripe billing                               | ✓ Webhooks + plan limits 402   |
| RAG / chatbot IA                             | ✓ Indexation + chat contextuel |
| Sécurité mobile G1–G6                        | ✓ 6 durcissements actifs       |
| Headers sécurité + healthchecks              | ✓ HSTS + CSP + COOP/CORP       |
| Auto-migration de schéma                     | ✓ BaseDataSchemaMigrator       |

### 10.2 Axes d'enrichissement planifiés

Liste des prochaines itérations produit, dans la continuité du périmètre V1 livré.

| Module                | Évolution planifiée                                                                                                                  |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Geofence              | Enrichissement de la documentation utilisateur (guide pas-à-pas de configuration des sites)                                          |
| RAG — fraîcheur index | Mise en place de la réindexation incrémentale automatique lors d'un dépôt sur le coffre-fort                                         |
| Onboarding tenant     | Enrichissement du guide de premier login ( <code>OnboardingGuide.tsx</code> ) avec parcours interactif                               |
| Sauvegardes           | Activation du planificateur cron sur le serveur de production (scripts <code>backup.sh</code> / <code>restore.sh</code> déjà livrés) |

## 11. Stratégie SaaS et segmentation des offres

### 11.1 Segmentation cible

| Segment                 | Profil                                               | Plan                   | Volume              |
|-------------------------|------------------------------------------------------|------------------------|---------------------|
| TPE / petites équipes   | 1-10 salariés, RH de base                            | Starter                | 10 inclus · cap 30  |
| PME en croissance       | 10-30 salariés, mobile + congés + paie               | Standard               | 15 inclus · cap 100 |
| Entreprises structurées | 30-200 salariés, sécurité renforcée + multi-filiales | Premium                | 30 inclus · cap 200 |
| Groupes / Comptes clés  | >200 salariés, API / SSO / hébergement dédié         | Enterprise (sur devis) | —                   |

### 11.2 Marché géographique prioritaire

1. **France** (cœur V1) : 4M+ PME, pression réglementaire (loi El Khomri, RGPD)
2. **Belgique** : extension naturelle, législation RH proche, marché francophone
3. **Maroc et Sénégal** : modernisation du pointage et de la paie pour PME / ETI locales — forte demande de digitalisation, peu d'offres adaptées au marché

### 11.3 Modèle d'abonnement

- **Facturation** : forfait mensuel fixe + overage par salarié supplémentaire. Périodicité *mensuelle ou annuelle*, au choix du client
- **Modèle Stripe** : subscription à 2 items — `base` (qty=1) + `seat` (qty=overage)
- **Engagement** : sans engagement de durée. L'utilisateur résilie à tout moment, selon deux modalités au choix :
  - *Résiliation immédiate* — effet instantané. **Si l'abonnement est annuel**, un remboursement *pro rata temporis* du temps non consommé est automatiquement émis sur la carte d'origine via la Refund API Stripe (cf. ci-dessous). **Si l'abonnement est mensuel**, aucun remboursement n'est appliqué — modalité conforme aux usages des abonnements SaaS mensuels reconductibles.
  - *Résiliation à l'échéance* — l'utilisateur conserve l'accès jusqu'au terme de la période déjà payée, aucune facturation ultérieure n'est émise. Aucun remboursement (la prestation est consommée

jusqu'au terme).

- **Mécanisme de remboursement prorata (annuel) :**

- **Périmètre** : applicable uniquement aux abonnements annuels résiliés en cours de période. Les abonnements mensuels ne donnent pas droit à remboursement (le mois en cours est dû, usage SaaS B2B standard).
  - **Calcul** :  $\text{montant remboursé} = \text{montant initialement payé} \times (\text{temps restant jusqu'à l'échéance} / \text{durée totale de la période annuelle})$ . Exemple : un Premium annuel facturé 1 428 € résilié à mi-parcours donne lieu à un remboursement de 714 €.
  - **Modalités** : remboursement crédité **sur la carte bancaire ayant servi au paiement initial** via la *Refund API* du prestataire de paiement (Stripe). Délai bancaire indicatif : 5 à 10 jours ouvrés selon la banque émettrice.
  - **Traçabilité** : chaque remboursement est tracé côté Stripe avec les métadonnées d'audit (référence subscription, référence facture initiale, ratio non consommé), exploitables en cas de contestation.
  - **Réponse client** : la confirmation de résiliation affichée à l'utilisateur indique le montant remboursé et la devise ; un mail récapitulatif est également envoyé.
  - **Continuité en cas d'incident** : si le remboursement automatique échoue pour une raison technique (carte expirée, refus banque, panne API), la résiliation reste effective, l'incident est journalisé et le support traite le remboursement manuellement sous 48 h ouvrées.
  - **Idempotence** : un éventuel renvoi de la demande de résiliation ne déclenche jamais un double remboursement (la résiliation effective court-circuite toute nouvelle exécution).
- **Essai** : 30 jours gratuits sur tous les packs payants, sans carte bancaire
  - **Job synchronisation seats** : `EmployeeBillingSyncService` (BackgroundService, 24 h)

## 12. Packs tarifaires et fonctionnalités

⚡ **Offre Early Launch — réservée aux 10 premières entreprises partenaires.** Tarifs préférentiels avec engagement annuel obligatoire et 1 mois gratuit sans carte bancaire. L'objectif de cette phase est de stabiliser la V1, accompagner finement les premiers clients et préparer la montée en charge progressive de la plateforme avant l'ouverture du tarif standard.

### 12.1 Pack Starter — 29,50 € / mois

**Cible** : TPE / petites équipes

**Tarif** : 29,50 € HT/mois — jusqu'à 10 salariés inclus — au-delà : +4,90 €/salarié supplémentaire

**Plafond pack** : 30 salariés maximum (au-delà : passer au pack supérieur)

**Stockage** : 5 Go inclus

**Essai** : 1 mois gratuit sans carte bancaire · engagement annuel

**Inclus** : Gestion RH de base, pointage web manuel, calendrier d'absences, tableau de bord simple, exports PDF/Excel basique, 1 administrateur, support standard.

**Désactivé (402 si appel direct)** : X App mobile X Pointage géolocalisé X Coffre numérique X Signature électronique X Multi-sites / sociétés X Assistant IA

## 12.2 Pack Standard — 54 € / mois POPULAIRE

**Cible** : PME en croissance · équipes terrain · structures multi-sites

**Tarif** : 54 € HT/mois — jusqu'à 15 salariés inclus — au-delà : +6,90 €/salarié supplémentaire

**Plafond pack** : 100 salariés maximum

**Stockage** : 20 Go inclus

**Essai** : 1 mois gratuit sans carte bancaire · engagement annuel

### Tout le Starter, plus :

- ✓ Application mobile (iOS + Android, biométrie, push)
- ✓ Pointage géolocalisé (geofence par site)
- ✓ Gestion congés complète (RTT, CET, sanctions)
- ✓ Coffre-fort numérique & signature électronique
- ✓ Notifications push + email + in-app
- ✓ Reporting avancé (PDF / Excel complets)
- ✓ Préparation paie (export Sage Excel)
- ✓ Multi-sites simple
- ✓ Support prioritaire (SLA 24 h)

**Désactivé** : ✗ Multi-sociétés / multi-filiales ✗ Assistant IA ✗ Device trust / Screenshot blocking runtime

## 12.3 Pack Premium — 149 € / mois

**Cible** : entreprises structurées · groupes multi-sites · besoins avancés sécurité & supervision

**Tarif** : 149 € HT/mois — jusqu'à 30 salariés inclus — au-delà : +9,90 €/salarié supplémentaire

**Plafond pack** : 200 salariés maximum (au-delà : offre Enterprise sur devis)

**Stockage** : 100 Go inclus

**Essai** : 1 mois gratuit sans carte bancaire · engagement annuel

### Tout le Standard, plus :

- ✓ Multi-filiales illimité + multi-sites illimité
- ✓ Tableaux de bord avancés (KPI temps réel)
- ✓ Audit logs avancés (export RGPD)
- ✓ Sécurité mobile renforcée ( useDeviceTrust + useSecureScreen actifs)
- ✓ Cert pinning (contractuellement Premium)
- ✓ Branding personnalisé · SLA premium
- ✓ Conformité RGPD avancée
- ✓ Onboarding accompagné (kick-off call, formation admin + manager)

**Roadmap V1.1 (add-on)** : API publique · SSO entreprise (SAML/OIDC) · Connecteurs paie directs (Sage, Cegid) · Assistant IA contextuel (RAG Qdrant + sidecar Python)

### 12.3 bis Offre Enterprise — sur devis

**Cible** : structures > 200 salariés · groupes multi-filiales complexes · besoins avancés non couverts par les packs standards.

**Périmètre adressé sur devis** : volumes importants · hébergement dédié · SLA spécifiques · intégrations avancées (ERP/paie) · sécurité renforcée (pen-test annuel, conformité sectorielle) · architecture personnalisée · multi-filiales complexes · accompagnement spécifique. Chiffrage sous 5 jours ouvrés après qualification du besoin.

### 12.4 Services et add-ons (sur devis, indépendants du pack)

Catalogue de prestations complémentaires souscriptibles à tout moment, indépendamment du pack commercial choisi (Starter / Standard / Premium). Tarifs personnalisés selon le périmètre — chiffrage sous 5 jours ouvrés après qualification du besoin.

| Catégorie              | Service                                  | Modalité                                                                                                              | Tarif     |
|------------------------|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Formation</b>       | Formation administrateurs (visio)        | Sessions à distance, 1 à 4 personnes, modules de 2 h                                                                  | Sur devis |
| <b>Formation</b>       | Formation sur site                       | Journée présentielle dans les locaux du client (France métropolitaine ; déplacement Outre-mer / international en sus) | Sur devis |
| <b>Intégration</b>     | API publique                             | Accès aux endpoints partenaires (token dédié, quota requêtes, sandbox)                                                | Sur devis |
| <b>Hébergement</b>     | Hébergement dédié                        | Instance isolée région FR / BE / MA, ressources réservées, plan de sauvegarde renforcé                                | Sur devis |
| <b>Sécurité</b>        | Pen-test annuel                          | Audit de sécurité externe par cabinet partenaire, rapport remédiation, retest inclus                                  | Sur devis |
| <b>Intégration</b>     | Connecteurs ERP / Paie standard          | Sage Paie, Cegid Quadra, Silae — intégration packagée                                                                 | Sur devis |
| <b>Intégration</b>     | Connecteurs ERP personnalisés            | Développement spécifique selon ERP du client                                                                          | Sur devis |
| <b>Mise en service</b> | Import de données assisté                | Récupération depuis ancien outil RH, nettoyage, mapping, import contrôlé                                              | Sur devis |
| <b>Mise en service</b> | Onboarding Premium                       | Kick-off call dédié, paramétrage initial du tenant, formation admin + manager incluse                                 | Sur devis |
| <b>Accompagnement</b>  | Coaching personnalisé (visio)            | Sessions de coaching à distance, format flexible (1–2 h)                                                              | Sur devis |
| <b>Accompagnement</b>  | Coaching personnalisé — demi-journée     | Session de 4 h, visio ou présentiel                                                                                   | Sur devis |
| <b>Accompagnement</b>  | Coaching personnalisé — journée complète | Session de 7 h, visio ou présentiel                                                                                   | Sur devis |

| Catégorie               | Service                  | Modalité                                                                                                                                                                            | Tarif     |
|-------------------------|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Support</b>          | Support prioritaire 24/7 | Astreinte 24 h / 24, 7 j / 7, SLA réponse renforcé (1 h ouvré / 4 h non ouvré)                                                                                                      | Sur devis |
| <b>Infrastructure</b>   | Stockage supplémentaire  | Quota additionnel pour le coffre numérique au-delà du seuil inclus dans le pack                                                                                                     | Sur devis |
| <b>Personnalisation</b> | Domaine personnalisé     | URL <code>&lt;client&gt;.com</code> ou <code>&lt;sous-domaine&gt;.&lt;client&gt;.com</code> à la place du sous-domaine <code>concorde-work-force.com</code> , certificats TLS gérés | Sur devis |

Toutes ces prestations font l'objet d'un devis dédié et d'un bon de commande contractualisé indépendamment du contrat d'abonnement principal. Elles sont facturées en EUR HT, conditions de paiement 30 jours net (sauf accord particulier).

## 13. Application mobile Concorde Workly



### Concorde Workly App mobile

Application compagnon iOS / Android destinée aux collaborateurs : pointage géolocalisé, congés, autorisations de sortie, notes de frais avec photo, coffre-fort numérique, signature électronique, notifications push, biométrie.

Identifiant technique `com.concorde.workly` · Version 1.0.0 · Android 8.0 (API 26) et supérieur · iOS 13+ (publication 2<sup>e</sup> semestre 2026)

### 13.1 Distribution & téléchargement

L'application est mise à disposition par téléchargement direct (fichier APK Android) avant publication sur le Google Play Store. Les utilisateurs autorisés récupèrent l'APK depuis leur interface web personnelle (rubrique *Téléchargements*) ou via le QR code ci-dessous. Publication App Store iOS planifiée au 2<sup>e</sup> semestre 2026.



**SCANNER POUR TÉLÉCHARGER**

Android · APK direct

|                          |                                                                                                                                   |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| <b>Lien APK direct</b>   | <a href="https://expo.dev/artifacts/eas/ihKV2zK34JH6UVG6aXgVJh.apk">https://expo.dev/artifacts/eas/ihKV2zK34JH6UVG6aXgVJh.apk</a> |
| <b>Interface web</b>     | Espace utilisateur → <i>Mon compte</i> → bouton <b>Télécharger l'application Android</b> (lien CDN à jour automatiquement)        |
| <b>Google Play Store</b> | Publication en cours de préparation (compte Developer + signature finale en attente)                                              |
| <b>Apple App Store</b>   | Planifié S2 2026 (compte Apple Developer + validation TestFlight)                                                                 |
| <b>Framework</b>         | React Native 0.81 + Expo SDK 54 (build natif EAS Build)                                                                           |

## 13.2 Permissions Android demandées

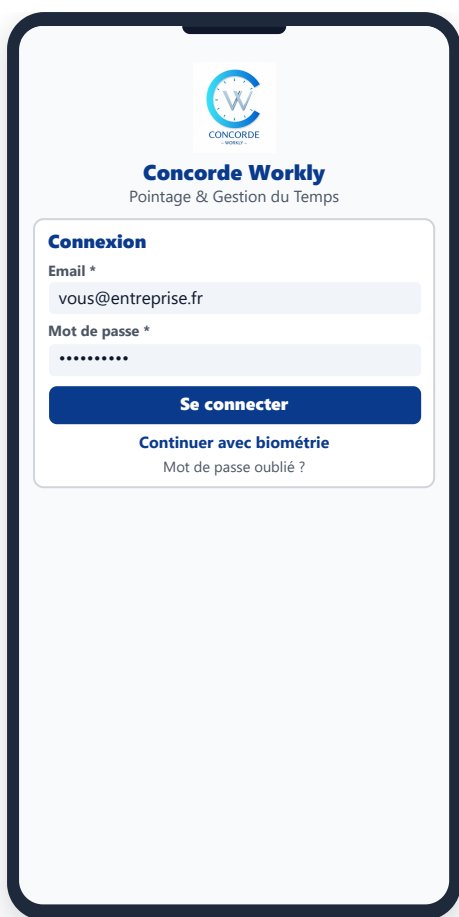
Toutes les permissions ci-dessous sont déclarées dans le manifeste Android et demandées à l'utilisateur **lors du premier usage de la fonctionnalité concernée** (pas au démarrage de l'application). Aucune permission « sensible » n'est demandée sans usage métier explicite.

| Permission Android                        | Usage et justification                                                                                                                                                                                                                                                              |
|-------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CAMERA                                    | Capture de justificatifs photo pour notes de frais, documents personnels et signatures. Demandée au déclenchement de la fonctionnalité de prise de photo uniquement.                                                                                                                |
| ACCESS_FINE_LOCATION                      | Géolocalisation <b>au moment du pointage uniquement</b> , lorsque la fonction est activée par l'employeur. Aucun suivi en arrière-plan. La position vérifie l'appartenance à la zone autorisée ( <i>geofence</i> ) puis est journalisée pour audit anti-fraude (rétention 12 mois). |
| POST_NOTIFICATIONS                        | Affichage des notifications push : approbation/refus de demande, rappels de pointage, alertes opérationnelles. Obligatoire sur Android 13+ (consentement explicite utilisateur).                                                                                                    |
| USE_BIOMETRIC · USE_FINGERPRINT           | Authentification biométrique (empreinte ou reconnaissance faciale) après le premier login. Le mot de passe n'est <b>jamais</b> stocké sur l'appareil : seul un bio-token serveur HMAC est conservé dans le keystore.                                                                |
| RECORD_AUDIO                              | Réservée à de futures fonctionnalités vocales (saisie dictée des notes), <b>non activée à ce jour</b> . Aucune capture audio n'est effectuée tant que la fonction n'est pas livrée. Déclarée pour permettre une évolution sans re-publication store.                                |
| VIBRATE · WAKE_LOCK                       | Vibration lors des notifications ; maintien temporaire de l'écran allumé pendant la signature électronique (évite la coupure d'écran en pleine signature).                                                                                                                          |
| READ_EXTERNAL_STORAGE · READ_MEDIA_IMAGES | Sélection d'une photo existante depuis la galerie pour les notes de frais. Lecture limitée aux images sélectionnées par l'utilisateur (Android 13+ <i>Photo Picker</i> ).                                                                                                           |
| INTERNET · ACCESS_NETWORK_STATE           | Communication HTTPS avec le serveur Concorde Workforce (canal verrouillé par <i>certificate pinning</i> sur le plan Premium). Détection on-line / off-line pour bufferiser les pointages hors-ligne.                                                                                |

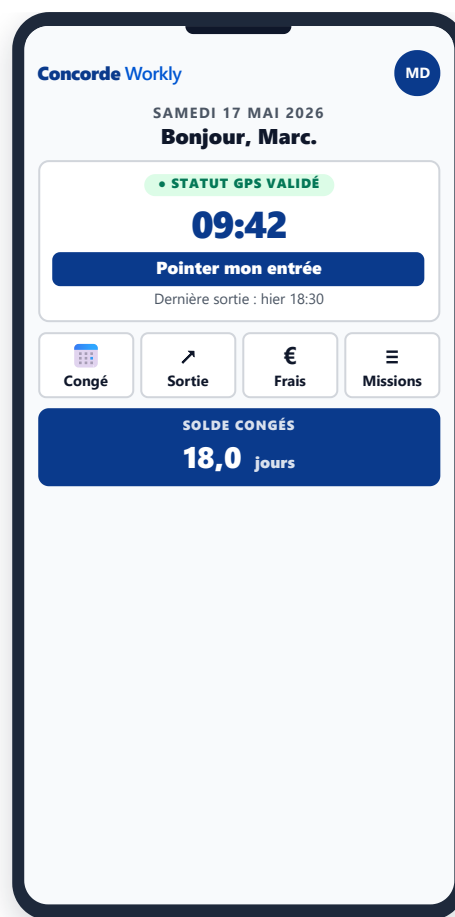
## 13.3 Captures d'interface mobile (extraits significatifs)

Aperçu fidèle des écrans principaux reproduits depuis le code source de `abrpoint.mobile/src/screens/`. La palette de couleurs, les libellés et la hiérarchie correspondent à la maquette Material 3 effectivement livrée.





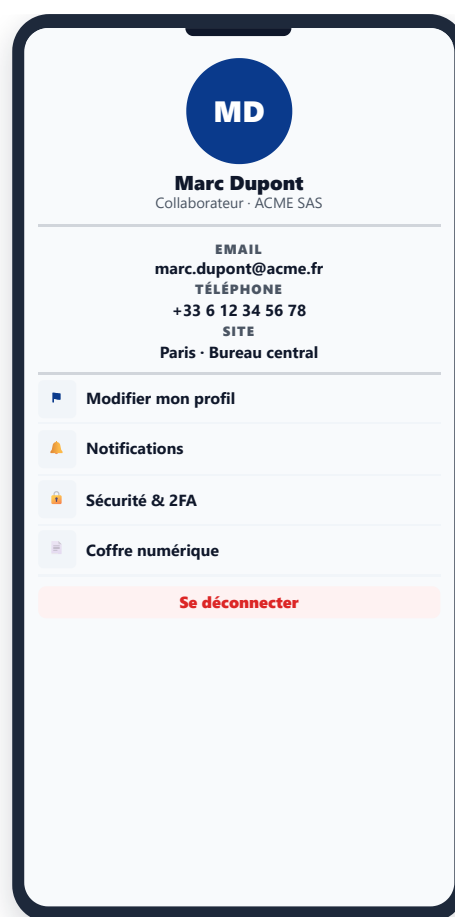
Connexion — email + mot de passe ou biométrie



Accueil — pointage GPS, raccourcis et soldes



Congés — soldes, calendrier et demandes en cours



Profil — informations, paramètres et coffre numérique

Les écrans sont reproduits depuis le code source en vigueur ([abrpoint.mobile/src/screens/](http://abrpoint.mobile/src/screens/)) pour garantir la fidélité visuelle à l'expérience livrée. Les captures haute résolution destinées aux store listings seront produites avant publication officielle Google Play / App Store.

## 13.4 Prérequis publication stores

| Google Play                                                                                                                                                                                                                                                                                                                                                                                                                               | App Store iOS                                                                                                                                                                                                                                                                                                                                                                                           |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>Compte Google Play Developer (25 \$ one-shot)</li> <li>Keystore Android signé, backupé hors repo</li> <li>Build EAS Expo configuré ( eas.json prod / preview) ✓</li> <li>applicationId Android com.concorde.workly ✓</li> <li>Icône adaptive Android paddée ✓</li> <li>network_security_config.xml pour cert pinning prod ✓</li> <li>Politique de confidentialité publiée (URL requise)</li> </ul> | <ul style="list-style-type: none"> <li>Compte Apple Developer (99 \$/an)</li> <li>Certificats iOS (distribution + push) via Apple Developer Portal</li> <li>Bundle ID iOS distinct ✓</li> <li>Info.plist avec NSPinnedDomains + permissions ✓</li> <li>Versioning automatique via Expo ✓</li> <li>Test sur build TestFlight avant soumission</li> <li>Validation App Review (délai ~3 jours)</li> </ul> |

## 13.3 Risques de rejet anticipés

| Risque                                       | Mitigation                                                                |
|----------------------------------------------|---------------------------------------------------------------------------|
| Apple : « app trop similaire à un site web » | Justifier les fonctions natives : GPS, biométrie, push, capture signature |

| Risque                                     | Mitigation                                                                           |
|--------------------------------------------|--------------------------------------------------------------------------------------|
| Apple : usage géolocalisation arrière-plan | Pas d'arrière-plan — uniquement on-demand au pointage. À documenter en review notes. |
| Google : Data Safety incohérent            | Audit checklist data collected vs déclaré                                            |
| Cert pinning trop strict                   | Pinning conditionnel build prod uniquement ; dev pointe vers staging                 |

## 14. Éléments pour démonstrations commerciales

### 14.1 Scénarios de démo (15-20 min)

**Démo 1 — Pointage simplifié (5 min)** Connexion mobile employé → pointage entrée avec GPS → vue temps réel admin → tentative hors zone → refus 422.

**Démo 2 — Cycle congé complet (5 min)** Demande mobile → notification manager → approbation → notification employé → solde mis à jour + titre PDF.

**Démo 3 — Coffre-fort & signature (5 min)** Upload bulletin → notification employé → signature tactile → statut signé verrouillé → audit log.

**Démo 4 — Préparation paie (5 min)** Pointage du mois agrégé → export Excel → état périodique PDF → KPIs dashboard.

### 14.2 Arguments différenciants

1. **Sécurité mobile bancaire** : cert pinning + screenshot blocking + auto-lock + bio-token sans password (rare sur le marché RH)
2. **IA contextuelle** : assistant RAG sur vos documents — pas sur des données génériques
3. **Multi-tenant strict** : 1 base SQL par client, isolation forte, hébergement région possible
4. **Mobile-first** : 22 écrans natifs, pas une web-view dégradée
5. **Geofence natif** : inclus dès Standard, pas un add-on
6. **Conformité RGPD** : retention dates, soft delete, export, registre, audit log
7. **Internationalisation** : FR/EN + multi-devises + tolérance horloge DST-safe

## 15. Scénarios opérationnels anticipés

Cette section recense les scénarios d'exploitation pour lesquels des mesures préventives ont été mises en place, conformément aux bonnes pratiques SaaS de continuité de service.

| Scénario opérationnel anticipé        | Mesures préventives en place                                                                                                                                             |
|---------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Continuité de service base de données | Sauvegardes horaires chiffrées hors site (S3 EU), procédure de restauration documentée et testée mensuellement, plan de bascule disponible pour les déploiements Premium |
| Notifications push à grande échelle   | Monitoring du volume Expo Push avec seuils d'alerte, capacité de bascule sur FCM en direct si nécessaire                                                                 |

| Scénario opérationnel anticipé              | Mesures préventives en place                                                                                                                               |
|---------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Croissance des volumes de stockage          | Alerte à 80 % d'utilisation, politique de rotation et d'archivage des fichiers anciens                                                                     |
| Synchronisation événements Stripe           | Tâche de réconciliation quotidienne entre Stripe et la base interne, signature des webhooks vérifiée                                                       |
| Maîtrise des coûts IA                       | Quotas par tenant configurables, modèles secondaires moins coûteux disponibles en fallback automatique                                                     |
| Veille de sécurité dépendances              | <code>dotnet list package --vulnerable</code> intégré au pipeline CI, Dependabot actif sur les dépôts (notifications immédiates sur CVE publiées)          |
| Continuité du pinning de certificats mobile | Pinning des certificats intermédiaires Let's Encrypt R10/R11 (et non du certificat feuille), procédure documentée pour rotation anticipée avant expiration |

## 16. Roadmap de développement

### 16.1 Phase 1 — Hardening V1 (T+0 à T+3 semaines)

- ✓ Plan gating end-to-end (backend + frontend + mobile)
- ✓ Tarification commerciale verrouillée + Stripe base+seat
- ✓ Période d'essai 30 j sans CB
- ✓ Job synchronisation seats Stripe (BackgroundService quotidien)
- ✓ CSP `frame-src blob:` pour aperçus PDF
- Backups uploads + SQL automatisés (cron production)
- Monitoring Prometheus + alerting
- Pen-test externe et remédiation
- Documentation utilisateur (admin & employé)
- Build EAS production iOS + Android signés
- Serveur Ubuntu 24.04 LTS durci — commande passée, mise en place \$17

### 16.2 Phase 2 — Lancement V1 (T+3 à T+5 semaines)

Pricing public, Stripe live, onboarding guidé enrichi, centre d'aide / FAQ, status page publique, métriques business (MRR, churn), soumission stores.

### 16.3 Phase 3 — V1.1 (T+6 à T+10 semaines)

Redis + scale horizontal, queue rapports asynchrone (Hangfire), réindexation RAG automatique, connecteurs paie (Sage, Cegid), API publique, SSO (SAML/OIDC), moteur branding, mode offline mobile.

### 16.4 Phase 4 — V2 (T+3 mois et plus)

Workflow personnalisable (BPMN-light), multi-langue étendu (AR, ES), hébergement régional (FR / BE / MA / SN), failover PostgreSQL (réplication streaming) + load balancer multi-AZ (Premium SLA 99,9 %).

## 17. Plan de durcissement infrastructure de production

### 17.1 Spécifications du serveur commandé

| Caractéristique   | Valeur retenue               | Justification                                                                                                     |
|-------------------|------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Hébergeur         | OVHcloud — datacenter France | Souveraineté des données + conformité RGPD (CNIL), garantie de traitement sur le territoire de l'Union européenne |
| Modèle de serveur | Serveur dédié OVH KS-5-B     | Ressources physiques exclusivement allouées à Concorde Workforce (pas de mutualisation avec d'autres clients)     |
| OS                | Ubuntu Server 24.04 LTS      | Support de sécurité jusqu'en avril 2029, .NET 8 supporté                                                          |
| Stockage          | SSD NVMe                     | Performance PostgreSQL (WAL + index) + génération des rapports synchrones                                         |
| RAM               | 64 Go                        | shared_buffers PostgreSQL typiquement 25 % ; reste partagé entre Kestrel, nginx, Qdrant, sidecar RAG              |
| Architecture      | Évolutive                    | Compatible déploiement multi-instance + cache Redis pour la croissance                                            |

### 17.2 Architecture cible (3 environnements)

|                 |                |                 |
|-----------------|----------------|-----------------|
| +-----+         | +-----+        | +-----+         |
| PRODUCTION      | STAGING        | TESTS / CI      |
| *.concorde-...  | staging.*      | ephemere docker |
| Stripe live     | Stripe test    | data reinit.    |
| Donnees reelles | Dump anonymise | pas de backup   |
| Backups quotid. | Backups hebdo  |                 |
| +-----+         | +-----+        | +-----+         |

### 17.3 Étapes de sécurisation

#### Phase 0 — Provisioning initial (J0 à J+1)

1. Installation Ubuntu Server 24.04 LTS (partition `/var/lib/docker` séparée)
2. Utilisateur `concorde-ops` non-privilégié avec `sudo`, désactivation root
3. SSH par clé uniquement ( `PasswordAuthentication no` , `PermitRootLogin no` )
4. `ufw` : INPUT default deny ; autoriser 22/tcp (SSH), 80/tcp, 443/tcp
5. `fail2ban` sur sshd (jail 24 h après 3 tentatives)
6. `unattended-upgrades` pour mises à jour sécurité automatiques
7. `auditd` activé (logs syscalls sensibles)

#### Phase 1 — Stack applicative

Docker Engine + Docker Compose v2 (repo officiel), volumes dédiés NVMe, premier `docker compose up -d` avec healthchecks.

## Phase 2 — DNS et TLS

Pointage A/AAAA `concorde-work-force.com` + wildcard `*.concorde-work-force.com`, certbot DNS-01 challenge, HSTS preload après stabilisation 1 semaine.

## Phase 3 — Monitoring

UptimeRobot sur `/api/healthz` (1 min) + `/readyz` (5 min), logs centralisés, alertes (5xx > 1 %, p95 > 2 s, disque > 80 %, certs < 14 j).

## 17.4 Politique de sauvegarde

| Quoi                             | Quand                                               | Où            | Rétention                      | Test restore |
|----------------------------------|-----------------------------------------------------|---------------|--------------------------------|--------------|
| PostgreSQL (master + tenants)    | Quotidien 03:00 UTC ( <code>pg_dump</code> chiffré) | S3 EU chiffré | 30 j rolling + 12 fins de mois | Mensuel      |
| Volume <code>uploads_data</code> | Quotidien 03:30 UTC                                 | Idem          | 30 j rolling                   | Mensuel      |
| Config nginx / appsettings       | Git + snapshot hebdo                                | Git + S3      | Indéfini                       | Sur modif.   |
| Volume Qdrant (RAG)              | Hebdomadaire                                        | Idem          | 4 semaines                     | Trimestriel  |

## 17.5 Plan de continuité de service (V1)

- **RPO cible** : 24 h (sauvegarde quotidienne)
- **RTO cible** : 4 h (restauration + redéploiement)
- **Modèle de résilience V1** : architecture mono-instance avec sauvegardes testées et procédure de restauration documentée — dimensionnée pour un engagement de service de niveau Standard (99 %). La haute disponibilité avec bascule automatique (réplication PostgreSQL streaming + load balancer multi-AZ) est planifiée dans le palier Premium SLA 99,9 % (cf. §9.2 roadmap).

# 18. Services tiers et dépendances

## 18.1 Services externes payants

| Service                       | Usage                          | Plan V1                                |
|-------------------------------|--------------------------------|----------------------------------------|
| Stripe                        | Billing abonnements + webhooks | Standard, frais 1,4 % + 0,25 € EU      |
| OpenRouter (Gemini 2.0 Flash) | LLM RAG                        | Pay-as-you-go ; switch Claude possible |
| Expo Push API                 | Notifications mobile           | Gratuit (~6000 push/min)               |
| Let's Encrypt                 | TLS                            | Gratuit                                |
| SMTP (TBD)                    | Emails transactionnels         | SendGrid / Mailgun / SES               |
| Apple Developer               | Distribution iOS               | 99 \$/an                               |
| Google Play Developer         | Distribution Android           | 25 \$ one-shot                         |

## 19. Annexes juridiques et conformité

Section annexée à l'attention du conseil juridique. Elle consolide, sans les recréer, les éléments épars dans le corps du document afin de faciliter la rédaction des CGV / DPA / politique de confidentialité et la tenue du registre des traitements (art. 30 RGPD). Toutes les durées et finalités citées sont implémentées dans le code (références entre crochets) ; toute évolution doit être propagée simultanément ici, dans le code et dans les documents contractuels publiés.

### 19.1 Sous-processeurs (art. 28 RGPD)

Le service est hébergé en France et la chaîne de sous-traitance est volontairement limitée. Liste exhaustive à date :

| Sous-processeur                     | Localisation | Finalité                                               | Données traitées                                                                                     | Encadrement                                                                                                |
|-------------------------------------|--------------|--------------------------------------------------------|------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <b>OVHcloud</b> (OVH SAS)           | France       | Hébergement serveur dédié + sauvegardes Object Storage | Toutes données plateforme (base SQL, uploads, logs)                                                  | DPA OVHcloud signé, datacenter UE (Roubaix / Gravelines), ISO 27001                                        |
| <b>Stripe Payments Europe Ltd</b>   | Irlande      | Encaissement abonnements, traitement CB                | Email admin, raison sociale, identifiant entreprise, montant, IP de paiement, 4 derniers chiffres CB | DPA Stripe (Stripe Connect), certifié PCI-DSS niveau 1                                                     |
| <b>HIBP</b> (Have I Been Pwned)     | Royaume-Uni  | Vérification mot de passe compromis                    | <b>Aucune PII transférée</b> — seulement les 5 premiers hex SHA-1 (k-anonymity)                      | Décision d'adéquation UE en vigueur. Pas de DPA requis (pas de donnée personnelle au sens RGPD)            |
| <b>api-recherche-entreprises.fr</b> | France       | Validation SIRET au signup                             | SIRET (donnée publique INSEE)                                                                        | Service public ouvert (DINUM), donnée publique légalement                                                  |
| <b>cbeapi.be</b>                    | Belgique     | Validation BCE au signup                               | BCE (donnée publique)                                                                                | Donnée publique légalement (UE)                                                                            |
| <b>restcountries.com</b>            | UE           | Liste pays + drapeaux signup                           | <b>Aucune donnée utilisateur transmise</b> — JSON public côté navigateur                             | Pas de transfert de données utilisateur                                                                    |
| <b>OpenRouter Inc.</b>              | États-Unis   | Inférence LLM RAG (Premium uniquement)                 | Extrait document (chunk ~500 tokens) + question utilisateur                                          | <b>Transfert hors UE</b> encadré par CCT / DPF. Alternative Anthropic UE possible. Désactivable par tenant |
| <b>Expo Push API</b> (Expo Inc.)    | États-Unis   | Notifications push mobile                              | Token Expo (opaque), corps notification (sans PII détaillée)                                         | Pass-through, corps conçus sans PII sensible                                                               |

| Sous-processeur                                     | Localisation | Finalité               | Données traitées               | Encadrement                  |
|-----------------------------------------------------|--------------|------------------------|--------------------------------|------------------------------|
| <b>OVH SMTP</b>                                     | France       | Emails transactionnels | Adresse email, contenu         | Inclus contrat OVHcloud      |
| <b>Let's Encrypt</b>                                | États-Unis   | Certificats TLS        | Nom de domaine (CT log public) | ISRG, pas de PII utilisateur |
| <b>Apple Push Notification</b><br>(roadmap)         | États-Unis   | Push iOS               | Token APNs, corps notification | CCT, opt-in OS               |
| <b>Google Firebase Cloud Messaging</b><br>(roadmap) | États-Unis   | Push Android           | Token FCM, corps notification  | CCT, opt-in OS               |

**Note HIBP / k-anonymity** : le protocole *Pwned Passwords* envoie au serveur HIBP les **5 premiers caractères hexadécimaux** du SHA-1 du mot de passe ; il reçoit en retour une liste de hashes suffixes complétant ce préfixe, et la comparaison finale a lieu côté serveur Concorde. Le mot de passe en clair, son hash complet, et l'identité de l'utilisateur ne sortent à aucun moment de notre infrastructure. La CNIL et l'ICO britannique considèrent ce protocole comme *non-identifiant* — il n'est donc pas qualifié de transfert de données personnelles au sens RGPD.

## 19.2 Bases légales de traitement (art. 6 RGPD)

| Finalité                                                                   | Base légale                                                                                                              | Référence interne                                                                               |
|----------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Fourniture du service (comptes, pointage, congés, paie, coffre, signature) | <b>Exécution du contrat</b> (art. 6.1.b)                                                                                 | CGV §3, §3                                                                                      |
| Facturation et encaissement                                                | <b>Exécution du contrat + Obligation légale</b> (art. 6.1.c)                                                             | §11.3, §3.12                                                                                    |
| Conservation bulletins de paie et contrats salariés                        | <b>Obligation légale</b> (Code du travail L.3243-4, D.3171-16 — 5 ans)                                                   | §19.3, §17.5                                                                                    |
| Anti-fraude SIRET / index unique filtré                                    | <b>Intérêt légitime</b> (art. 6.1.f) — prévention fraude commerciale                                                     | §6.5                                                                                            |
| Vérification HIBP, logout, alerte nouvel appareil                          | <b>Obligation légale de sécurité</b> (art. 32) + <b>Intérêt légitime</b>                                                 | §3.1, §6.5                                                                                      |
| Géolocalisation au pointage                                                | <b>Exécution du contrat de travail</b> côté client final + Information préalable des salariés (Code du travail L.1222-4) | §3.4 — l'éditeur fournit l'outil, le tenant employeur est responsable de la base opérationnelle |
| Notifications push commerciales / rappels essai                            | <b>Consentement</b> (art. 6.1.a) — opt-in <code>NotificationUserSettings</code>                                          | §3.9                                                                                            |
| Logs d'audit et journalisation sécurité                                    | <b>Obligation légale de sécurité</b> (art. 32) + <b>Intérêt légitime</b>                                                 | §6.1, table <code>AuditLog</code>                                                               |
| Assistant IA (RAG)                                                         | <b>Consentement</b> explicite tenant Premium ; transfert hors UE encadré                                                 | §3.11, §19.1                                                                                    |



### 19.3 Durées de conservation des données

Politique de rétention par catégorie. Les durées « légales » s'imposent ; les durées « contractuelles » sont configurables par tenant dans les limites des minimums légaux.

| Catégorie                                | Durée                                                     | Fondement                                                | Mise en œuvre                                                   |
|------------------------------------------|-----------------------------------------------------------|----------------------------------------------------------|-----------------------------------------------------------------|
| Compte utilisateur actif                 | Durée du contrat + 30 j de grâce                          | Contrat                                                  | Soft-delete après inactivité, suppression effective sur demande |
| Bulletins de paie générés                | 5 ans                                                     | Code du travail art. L.3243-4                            | Coffre numérique chiffré, purge automatique au-delà             |
| Données de pointage / présence           | 5 ans (souvent 1 à 3 ans en pratique)                     | Code du travail art. D.3171-16 ; contractuel             | Table <code>Presence</code> , archivage froid > 13 mois         |
| Coordonnées GPS journalisées au pointage | <b>12 mois maximum</b> par défaut                         | CNIL — délibération 2018-101, lignes directrices RH      | Configurable côté tenant, purge planifiée                       |
| Logs de connexion / authentification     | 12 mois                                                   | LCEN art. 6-II + recommandations ANSSI/CNIL              | Table <code>AuditLog</code> , rotation logs nginx 12 mois       |
| Refresh tokens / sessions                | Inactif > 30 j révoqué ; quota 5 actifs / utilisateur     | Sécurité art. 32 RGPD                                    | Cleanup background + quota G6                                   |
| Données de facturation Stripe            | 10 ans                                                    | Code de commerce L.123-22 (pièces comptables)            | Stripe conserve nativement                                      |
| Tenant résilié                           | <b>90 jours en rétention</b> → puis suppression effective | Contractuel + RGPD <i>droit à l'effacement</i> (art. 17) | Statut <code>Cancelled</code> , purge planifiée J+90            |
| Données après droit à l'effacement       | 30 j max                                                  | RGPD art. 17, 12                                         | Procédure documentée, registre des suppressions                 |
| Embeddings RAG (Premium)                 | Durée du contrat + suppression à la résiliation           | Contractuel                                              | Qdrant collections par tenant, purgeables                       |
| Sauvegardes chiffrées                    | 30 j rolling + 1 fin de mois × 12                         | Contrat de service / RTO                                 | §24.4                                                           |

### 19.4 Récapitulatif des engagements contractuels

Synthèse des engagements de l'éditeur opposables au client, à reprendre tels quels (ou à raffiner) dans les CGV.

| Engagement                | Modalité actuelle                                                                                                                 | Référence |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Essai gratuit</b>      | 30 jours sur tous les plans (Starter / Standard / Premium), <b>sans carte bancaire requise</b> , accès aux modules du plan choisi | §11.3     |
| <b>Durée d'engagement</b> | Sans engagement de durée. L'utilisateur résilie à tout moment                                                                     | §11.3     |

| Engagement                               | Modalité actuelle                                                                                                                                   | Référence                         |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|
| <b>Résiliation à l'échéance</b>          | Accès maintenu jusqu'au terme de la période payée, aucune facturation ultérieure                                                                    | \$11.3, \$3.12                    |
| <b>Résiliation immédiate — mensuel</b>   | Effet instantané, <b>pas de remboursement</b> du mois en cours                                                                                      | \$11.3                            |
| <b>Résiliation immédiate — annuel</b>    | Effet instantané, <b>remboursement prorata temporis automatique</b> sur la CB d'origine (Stripe Refund API), délai bancaire 5–10 jours ouvrés       | \$11.3, [StripeBillingService.cs] |
| <b>Rétention post-résiliation</b>        | 90 jours de réactivation self-service ; au-delà, suppression effective (sauf obligations légales concurrentes : bulletins 5 ans)                    | \$3.12                            |
| <b>Hébergement</b>                       | France (OVH Roubaix / Gravelines) — données primaires et sauvegardes en UE                                                                          | \$19.1, \$17.5                    |
| <b>Conformité RGPD</b>                   | Plateforme conçue <i>privacy by design</i> , DPA disponible, registre des traitements interne tenu                                                  | \$17.5                            |
| <b>Sécurité</b>                          | Mesures conformes art. 32 RGPD (TLS 1.2+, LUKE, BCrypt, refresh tokens AES, logout, HIBP, alerte nouvel appareil)                                   | \$6, \$6.5                        |
| <b>Disponibilité</b>                     | SLA Standard 99 % (V1), Premium 99,9 % (palier roadmap)                                                                                             | \$17.5                            |
| <b>Notification d'incident</b>           | Notification client sous 72 h conformément à l'art. 33 RGPD si fuite de données personnelles affecte ses utilisateurs                               | À formaliser CGV                  |
| <b>Audit client</b>                      | Possibilité d'audit annuel de conformité (modalités CGV : préavis raisonnable, frais éventuels)                                                     | À formaliser CGV                  |
| <b>Signature électronique</b>            | Valeur probante de niveau « simple » au sens eIDAS (règlement UE 910/2014) — horodatage, IP, hash document conservés ; <b>non qualifiée</b>         | \$3.8                             |
| <b>Validation identifiant entreprise</b> | SIRET / BCE / ICE / NINEA vérifiés contre registres officiels au signup ; un même établissement ne peut bénéficier que d'un essai gratuit à la fois | \$3.12, \$6.5                     |

## 19.5 Transferts internationaux et garanties

| Transfert                                 | Justification                                                     | Garantie applicable                                                                                          |
|-------------------------------------------|-------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| <b>HIBP (UK)</b>                          | Pas un transfert de données personnelles (k-anonymity, cf. §19.1) | Sans objet                                                                                                   |
| <b>OpenRouter (US)</b>                    | Sous-traitant IA pour la fonctionnalité RAG Premium               | Clauses contractuelles types UE→US et/ou inscription DPF, <b>opt-in</b> au niveau du tenant via feature flag |
| <b>Expo Push (US), Let's Encrypt (US)</b> | Services techniques (push token, certificats domaine)             | Pas de PII utilisateur transférée ; CCT applicables                                                          |
| <b>APNs / FCM (US)</b>                    | Notifications mobile via stores                                   | Inhérent aux écosystèmes Apple / Google, opt-in via permissions OS                                           |

## 20. Conclusion

La plateforme est dans un état de **maturité fonctionnelle élevée** : modules métier complets, multi-tenant opérationnel avec auto-migration de schéma, calculs paie couverts par tests, sécurité socle forte et durcissements mobiles bancaires (cert pinning, bio-token, device trust, screenshot blocking, auto-lock, RT quota) — les deux derniers gâtés Premium au runtime. La plateforme intègre **une couche anti-fraude au signup** (identifiant entreprise vérifié auprès des registres officiels Sirene/CBE, index unique filtré pour empêcher la multi-inscription gratuite, sélecteur pays FR/BE/MA/SN dynamique, filtrage des emails grand public) **et un durcissement de l'authentification** (lockout progressif, vérification HIBP des mots de passe, alerte instantanée sur nouvel appareil avec révocation HMAC). Côté paiement, **idempotence Stripe Checkout, anti-replay des webhooks** et **validation server-side du userCount** ferment les vecteurs classiques (double facturation, jeu, sous-déclaration).

La **tarification Early Launch** (Starter 29,50 € · Standard 54 € · Premium 149 €), *réservée aux 10 premières entreprises partenaires avec engagement annuel*, repose sur un modèle forfait + overage par salarié, avec un mois gratuit sans CB et facturation Stripe à 2 items (forfait + produit unique `user_supp` pour les collaborateurs supplémentaires). Chaque pack a un **plafond absolu** de salariés (30 · 100 · 200) au-delà duquel un upgrade — ou l'offre Entreprise sur devis — est requis. La **politique de résiliation** est alignée sur l'engagement payé d'avance : **remboursement prorata temporis automatique sur les abonnements annuels** (Refund API Stripe vers la carte d'origine, métadonnées tracées pour audit) ; les abonnements mensuels conservent l'usage SaaS B2B standard (mois en cours dû, pas de remboursement).

Le **plan gating est appliqué de bout en bout** : backend (`RequirePlanFeatureAttribute`), frontend (`planAllows`), mobile (hooks conditionnés au plan). Un tenant Starter ne peut pas accéder à l'app mobile, au coffre, à la signature, au reporting avancé, ni à l'IA — y compris par appel direct à l'API.

Les **trois axes prioritaires** de la phase de mise en production sont :

1. **Continuité de service** : sauvegardes testées, monitoring, alerting — plan détaillé §17, déploiement planifié sur le serveur OVH KS-5-B nouvellement provisionné
2. **Audit sécurité externe** : pen-test indépendant — démarche complémentaire de validation pour les clients Premium, planifiée avant l'ouverture commerciale du palier Premium
3. **Tests de charge** sur le serveur dédié final, validant les capacités annoncées dans le SLA

L'architecture multi-tenant *DB-per-tenant* est adaptée au segment PME/ETI ciblé et offre une isolation forte. La stratégie commerciale tri-marché (France / Belgique / Afrique francophone) est cohérente avec les capacités techniques (multi-devises, skew horloge DST-safe, mobile-first).